

# BOXCYCLE 보안 분석 보고서

| 항목    | 내용                                               |
|-------|--------------------------------------------------|
| 문서 유형 | security-assessment (코드베이스 정적 분석)                |
| 작성일   | 2026-05-16                                       |
| 범위    | apps/web, functions, firestore.rules, 레거시 app.js |

## 1. 요약

| 구분       | 평가                                                                                                     |
|----------|--------------------------------------------------------------------------------------------------------|
| 전체       | 프로토타입-MVP 단계에는 적합하나, <b>Firestore</b> <code>courses</code> 생성 규칙과 봇-쿼터 남용 방어가 없어 운영 전 보완이 필요함          |
| 잘 된 부분   | Mapbox Directions 시크릿 서버 보관, ID 토큰 검증, 닉네임 예약-Rules 연동, 저장 경로-주행 기록 소유자 격리, 심사자 기반 공개 경로 승인            |
| 즉시 조치 권장 | <code>courses create</code> 규칙 강화, Cloud Functions/App Check-레이트 리밋, <code>coursePresence</code> 필드 검증 |

## 2. 아키텍처와 신뢰 경계

신뢰하는 것: Firebase Auth 세션, Firestore Rules, Functions의 `verifyIdToken`.

신뢰하지 않는 것: 클라이언트가 보내는 모든 Firestore 필드-표시명-코스 메타데이터.

흐름(요약): 브라우저(Vite React) → Firebase Auth / Firestore → `getMapboxDirections`에 Bearer ID Token → 서버가 시크릿으로 Mapbox 호출. `VITE_*` 환경 변수는 클라이언트에 노출될 수 있음.

## 3. 심각도별 발견 사항

### Critical — `courses` 임의 생성

파일: `firestore.rules` — `match /courses/{courseId}`

문제: 로그인(익명 포함) 사용자가 `visibility: "public"`, `presenceEnabled: true`, `status: "published"` 등 임의 필드로 코스 문서를 만들 수 있음. `create` 조건이 `routeFingerprint` 형식 외에 거의 제한이 없음.

영향:

- 가짜 공개 코스-대용량 geometry 삽입
- `presenceEnabled`로 동행(presence) 허브 위장 → `coursePresence` 읽기/쓰기 활성화
- `visibility == 'public'` 시 비로그인 읽기로 스팸 노출
- 공식 허브 ID 선점(squatting) 가능

권장: 클라이언트 `create` 금지. 코스 생성은 Cloud Functions(Admin SDK) 또는 `isRouteReviewer()` + 엄격한 `hasOnly / diff`만 허용. UGC는 `publicRouteRequests` 승인 경로만 사용.

## High

**H1. 익명 계정 + Mapbox 프록시 남용** — `verifyIdToken` 만으로 익명-Google 구분 없음. 레이트 리밋-App Check-UID별 쿼터 없으면 익명 대량 생성 후 비용-호출 폭주 가능.

**H2. `coursePresence / rooms/.../members` — `liveCourseRides` 는 `hasOnly` 등 제약이 있으나, 일부 `presence` 경로는 필드 무검증. API로 표시명-URL-대용량 필드 위조 가능.**

**H3. `publicRouteRequests` 대용량 `geometry`** — 단일 필드 상한이 크면 신청 스팸 시 저장-읽기 비용 증가 (DoS에 가까움).

**H4. `users` 전역 읽기** — 로그인만 하면 타 사용자 프로필 필드 조회 가능(프라이버시 리스크).

**H5. Firebase App Check 미사용** — 봇이 Auth-Firestore-Functions 직접 호출하기 쉬움.

## Medium

**M1. 클라이언트 노출 토큰** — `VITE_FIREBASE_*` (공개 전제), `VITE_MAPBOX_ACCESS_TOKEN` , `VITE_MAPILLARY_CLIENT_TOKEN` 은 URL 제한 없으면 타 도메인 도용 위험. `VITE_DIRECTIONS_DIRECT=1` 은 브라우저 직접 호출로 시크릿 우회.

**M2. 로그아웃 후 맵 유지** — 의도된 UX일 수 있으나 비로그인 기능 노출 범위 정책 명확화 필요.

**M3. 콘텐츠 검수** — 클라이언트 중심-선택 URL 모더레이션은 우회 가능. 최종 판단은 서버/Rules 권장.

**M4. Critical와 결합 시** — 심사 UI는 Rules에 의존하는 설계가 맞으나, `courses create`가 열려 있으면 심사 없이 공개 코스 생성 가능.

**M5. 레거시 `app.js`** — Firebase 없이 Mapbox 직접 호출. 배포에 포함 시 공격면 증가.

## Low / 정보

- `MapView.tsx` 의 `innerHTML` : 정적 SVG 상수만 삽입 시 XSS 위험 낮음.
- `nicknames get`: 닉네임 존재 여부 추측 가능.
- `rooms` 멤버: 같은 `roomId`를 아는 로그인 사용자 간 목록 열람.

---

## 4. 잘 구현된 보안 요소

1. Mapbox Directions 서버 프록시 — 시크릿은 `defineSecret` , 클라이언트는 ID 토큰만 전송.
2. 닉네임 — 트랜잭션 예약 + Rules `userNicknameReserved()` .
3. `savedRoutes / rides` — 소유자 격리, 주행 기록 `update/delete` 금지.
4. `publicRouteRequests` — 신청-심사자-상태 전이 Rules 제한.
5. `.gitignore` — `.env` , `config.local.js` 등.
6. Functions 입력 검증 — 좌표-profile-waypoints 개수.

---

## 5. 공격 시나리오 예시(텍스트)

1. 스크립트가 `signInAnonymously` 반복.
2. Firestore에 `courses` 스팸 문서 생성(공개-presence 허용 플러그).
3. 각 UID로 `getMapboxDirections` 호출 → Mapbox 쿼터 소진.

---

## 6. 우선순위별 권장 조치

| 우선순위 | 조치                                                                                                          |
|------|-------------------------------------------------------------------------------------------------------------|
| P0   | <code>courses</code> 클라이언트 <code>create</code> 금지 또는 <code>reviewer/seed</code> 전용·엄격한 <code>hasOnly</code> |
| P0   | <code>coursePresence-rooms/.../members</code> 에 <code>hasOnly</code> ·길이·URL 형식 검증                          |
| P1   | Firebase App Check + 레이트 리밋, 가능하면 익명 Directions 제한                                                          |
| P1   | <code>users read</code> 를 <code>isSelf</code> 또는 공개 프로필 분리                                                  |
| P2   | <code>geometry</code> 상한 축소·서버 검증, 모더레이션 Functions 이전                                                       |
| P2   | Mapbox/Mapillary 토큰 URL·스코프 제한 운영 체크                                                                        |
| P3   | 레거시 <code>app.js</code> 호스팅 제외, 프로덕션에서 <code>VITE_DIRECTIONS_DIRECT</code> 차단                               |

## 7. 인증·세션 메모

- 자동 익명 로그인 없음 — App Check 없으면 버튼 기반 익명 계정 자동화에 취약할 수 있음.
- Firebase 웹 API Key는 공개 전제 — 승인 도메인·App Check·Rules가 실질 방어선.
- `config/routeReviewers` — 최소 인원·정기 검토 권장.

## 8. 결론

현재는 로그인한 사용자를 넓게 신뢰하는 편이며, `courses create`와 일부 `presence` 쓰기가 가장 큰 구조적 취약점이다. Mapbox 시크릿 보호와 닉네임·공개 경로 Rules는 양호하나, 운영·비용·콘텐츠 무결성을 위해 P0-P1 조치 후 프로덕션 적합성을 재평가할 것을 권장한다.

본 보고서는 저장소 정적 분석에 기반하며, 배포 환경·Firebase Console 설정·실제 트래픽은 별도 검증이 필요하다.